

Security+ 4.5 · Email Security

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.5 — Email Security (7:05)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: SPF (lista de IP autorizado), DKIM (assinatura da mensagem), DMARC (política: o que fazer se falhar — reject/quarantine + notifica o dono). Gateway security antispam/antivirus. Encryption: S/MIME, PGP. Sem DMARC qualquer um impersona o domínio.

Highlights que a prova cobra

- SPF: lista os IP autorizado; DKIM: assina o corpo
- DMARC: a política — reject/quarantine quando falha; protege contra spoof

Dicas de prova & Cenários Típicos

- 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC

Cenário clássico de exame: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.5 — Email Security)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **DKIM:** DomainKeys Identified Mail: Assina digitalmente o cabeçalho e corpo de e-mails usando a chave privada do domínio remetente, permitindo ao destinatário validar a autenticidade.
- **SPF:** Sender Policy Framework: Registro DNS do tipo TXT que publica a lista autorizada de endereços IP autorizados a enviar e-mails em nome de determinado domínio.
- **DMARC:** Domain-based Message Authentication, Reporting, and Conformance: Política que define o que fazer com e-mails que falharem no SPF ou DKIM (none, quarantine ou reject) e gera relatórios.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

3. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'SPF: lista os IP autorizado; DKIM: assina o corpo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina o corpo...**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

4. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'DMARC: a política — reject/quarantine quando falha; protege contra spoof'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Implementar a solução correspondente: DMARC: a política — reject/quarantine quando falha; protege contra spoof...**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

5. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'SPF: lista os IP autorizado; DKIM: assina o corpo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina o corpo...

8. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'DMARC: a política — reject/quarantine quando falha; protege contra spoof'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DMARC: a política — reject/quarantine quando falha; protege contra spoof...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloque...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — BEC / CEO fraud (fraude do CEO).

✓ **Por que está certa:** A alternativa correta é 'BEC / CEO fraud (fraude do CEO)'. Business Email Compromise (BEC) é uma categoria de ataque de engenharia social em que o atacante se passa por um executivo de alto escalão (como o CEO) ou por um parceiro de negócios confiável para induzir funcionários a realizar transferências financeiras não autorizadas ou divulgar informações confidenciais. No caso descrito, o golpista envia um e-mail fraudulento se passando pelo CEO e ordena uma transferência urgente ao setor financeiro. Isso se enquadra perfeitamente na definição de BEC, que é reconhecida pela CompTIA como um vetor de ataque baseado em impersonação e engenharia social. A variante específica em que o CEO é personificado é chamada de CEO fraud. Portanto, a opção 'BEC / CEO fraud (fraude do CEO)' é a que melhor descreve o ataque.

✗ **Por que as outras estão erradas:**

- *Whaling*: Whaling é um tipo de ataque de phishing direcionado especificamente a executivos de alto nível (como CEOs, CFOs, etc.). O objetivo é obter informações confidenciais ou acesso a sistemas críticos por meio de e-mails fraudulentos que se passam por fontes confiáveis. No entanto, no cenário descrito, o atacante não está mirando o CEO, mas sim se passando por ele para enganar o setor financeiro. Portanto, whaling não é o termo correto, pois descreve o alvo (o executivo) e não o modus operandi de impersonação do CEO para fraudar subordinados.
- *Vishing*: Vishing é a prática de engenharia social realizada por meio de chamadas telefônicas (voice phishing), onde o atacante se passa por uma entidade confiável para obter informações sensíveis, como senhas ou dados financeiros. No enunciado, o ataque ocorre por e-mail, não por telefone. Portanto, vishing não se aplica ao canal utilizado. Além disso, o vishing não envolve necessariamente a personificação do CEO para ordenar transferências, mas sim ligações fraudulentas em geral.
- *Tailgating*: Tailgating é uma técnica de acesso físico não autorizado em que uma pessoa segue outra em uma área restrita sem se autenticar, geralmente explorando a cortesia ou distração do funcionário autorizado. Não tem relação com ataques de engenharia social por e-mail ou fraudes financeiras. O cenário descreve um ataque cibernético baseado em e-mail fraudulento, não uma invasão física. Portanto, tailgating é completamente inadequado para a situação.

2) A — Vishing.

✓ **Por que está certa:** A alternativa correta é 'Vishing'. Vishing é a combinação de 'voice' e 'phishing', ou seja, engenharia social realizada por meio de chamadas telefônicas (VoIP ou rede telefônica tradicional). No cenário descrito, o atacante se passa por suporte técnico para obter a senha da vítima, caracterizando exatamente um ataque de vishing. A CompTIA Security+ classifica vishing como um ataque de engenharia social baseado em voz, onde a interação em tempo real aumenta a pressão psicológica e a credibilidade percebida. O objetivo é induzir a vítima a revelar credenciais ou executar ações prejudiciais.

✗ **Por que as outras estão erradas:**

- *Pretexting*: Pretexting é a criação de um cenário ou pretexto falso para obter informações. Embora o atacante no enunciado use um pretexto (falso suporte técnico), o vetor principal é o telefone. Pretexting é um elemento comum em muitos ataques de engenharia social, incluindo vishing, phishing e smishing. A alternativa é incorreta porque não especifica o canal telefônico, que é a característica definidora do vishing. Em termos técnicos, pretexting é a técnica de construção da história, enquanto vishing é o meio de entrega via voz.
- *Baiting*: Baiting envolve deixar um dispositivo físico (como um pendrive infectado) ou uma isca digital para que a vítima o utilize, explorando a curiosidade. Não há relação com chamadas

telefônicas ou solicitação direta de senha por voz. A alternativa é incorreta porque descreve um ataque que depende de ação física ou interação com mídia removível, não de interação verbal em tempo real.

- *Tailgating*: Tailgating é uma técnica de acesso físico não autorizado em que o atacante segue um funcionário autorizado através de uma porta segura sem se autenticar. Não envolve telefone, engenharia social verbal ou obtenção de senha. A alternativa é incorreta porque pertence à categoria de ataques físicos, enquanto o cenário descreve um ataque remoto de engenharia social por voz.

3) B — Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina o corpo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): SPF: lista os IP autorizado; DKIM: assina o corpo.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: DMARC: a política — reject/quarantine quando falha; protege contra spoof....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): DMARC: a política — reject/quarantine quando falha; protege contra spoof.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina o corpo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): SPF: lista os IP autorizado; DKIM: assina o corpo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: DMARC: a política — reject/quarantine quando falha; protege contra spoof....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): DMARC: a política — reject/quarantine quando falha; protege contra spoof.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.